Week 9 defense sheet: risk scoring agent, AWS-sim vs on-prem

One agent, deployed twice, same unchanged code, same frozen input (sha256 5b5917e1...a121).

What is real vs simulated

REAL

- The Week 8 agent code, byte-identical (tested against commit 924d9c2)
- Local Ollama running both models; tokens and ms come from Ollama's counters
- Least-privilege linter and policy evaluation (exact match, no wildcards)
- run-task enforcement: denies before executing; 5 denial cases in the transcript, more in unit tests
- Digest discipline: deterministic archive, digest verified on pull, run by digest only

SIMULATED

- AWS itself: simaws is my own local control plane, arn:simaws: ARNs, JSON state
- No Docker image: a deterministic source archive stands in (Dockerfile shows the real shape)
- bedrock:InvokeModel is in the policy as the real-deployment shape; NOT enforced
- VPC: rules are validated, no actual routing; "model subnet" maps to local Ollama
- "On-prem" is a local process; the boundary check is a loopback/private-address check

Three tough questions

1. "If it is a simulation, what did you actually demonstrate?"
Design and enforcement logic, not AWS behavior: a role scoped to exact resources, a gate that refuses to run anything the role or network doesn't allow (shown by denials), and an agent that runs identically on a managed-style and a boundary-style target. I say plainly it is a simulation on every artifact; a real deployment changes the control plane, not the agent or the policy shape.

2. "Is the policy really least privilege? What about the exceptions?"
Four statements, each with a written reason, no wildcards, no write or read on logs beyond append, pull-only on one repo. Honest exceptions: real AWS requires Resource * for GetAuthorizationToken (I scope it in the sim and say so); InvokeModel is documented but unenforced because the model call is local Ollama; and a real private subnet needs VPC endpoints for ECR/S3/CloudWatch.

3. "The two models differ. Can you say the smaller model is worse?"
Only for this input and this run: one case, temperature 0, fixed seed. I graded both against a reference computed from the prompt's own rules, and compare tokens and latency. The Week 8 code recomputes the sum but does not fix wrong per-factor points, so a wrong factor is a wrong score, which is why on-prem would add human review near thresholds. It is evidence, not a ranking.

Recommendation in one breath

Strict residency: on-prem Ollama, pinned model version, accept lower quality, human review near thresholds. No residency constraint: AWS with managed model, dedicated role, private subnets plus endpoints. Same agent code either way; the model sits behind the LLMClient interface.

Key numbers

- 4 IAM statements, 0 wildcards; trust principal ecs-tasks.amazonaws.com only
- Network: 1 private app subnet 10.0.1.0/24, 0 ingress, exactly 1 egress tcp/11434 to 10.0.2.0/24; model SG: ingress only from task SG, no egress
- Unit tests: pytest, all green without Ollama (MockTransport and a local API test double)

Measured token and latency numbers come from evidence/comparison_numbers.txt after the run; rebuild this sheet then to embed them.